

# CARBON6

# MOBILE COMPROMISE RESPONSE GUIDE

Executive and Military Leadership Field Manual

## EXECUTIVE DOCTRINE

Stop sensitive use. Move the device out of the decision space. Report through a known-good channel.  
Preserve first, investigate second, and recover from a clean platform.

|                 |                                  |
|-----------------|----------------------------------|
| Document        | GN-IR-MOBILE-001                 |
| Edition         | 1.2 — supersedes 1.1             |
| Effective       | August 20, 2026                  |
| Accuracy review | Quarterly                        |
| Document owner  | GreyNOC Cybersecurity Operations |
| Classification  | Public defensive guidance        |

# Contents

|                                                                         |           |                                                                         |           |
|-------------------------------------------------------------------------|-----------|-------------------------------------------------------------------------|-----------|
| <b>Read This First . . . . .</b>                                        | <b>2</b>  | Counter-impersonation controls . . . . .                                | 13        |
| How to use this manual . . . . .                                        | 2         | Exposure review for meetings and movements . . . . .                    | 13        |
| What “known-good” means . . . . .                                       | 2         | <b>Investigate, Correlate, and Decide . . . . .</b>                     | <b>14</b> |
| Emergency contact card — complete before issue . . . . .                | 2         | Investigation workstreams . . . . .                                     | 14        |
| <b>60-Second Executive Action Card . . . . .</b>                        | <b>3</b>  | Evidence standards . . . . .                                            | 14        |
| Never do these on your own . . . . .                                    | 3         | Timeline anchors . . . . .                                              | 15        |
| Immediate mission and safety exception . . . . .                        | 3         | <b>Recover From a Known-Good Platform . . . . .</b>                     | <b>15</b> |
| <b>Containment Choice . . . . .</b>                                     | <b>4</b>  | Recovery tiers . . . . .                                                | 15        |
| Containment decision log . . . . .                                      | 5         | Clean provisioning standard . . . . .                                   | 15        |
| <b>Threat Model . . . . .</b>                                           | <b>5</b>  | Return-to-service gate . . . . .                                        | 16        |
| Mobile compromise exposure path . . . . .                               | 5         | <b>iPhone . . . . .</b>                                                 | <b>16</b> |
| Six hypotheses to test . . . . .                                        | 5         | When compromise is suspected . . . . .                                  | 16        |
| <b>Severity Without Panic . . . . .</b>                                 | <b>6</b>  | Verifying an Apple threat notification . . . . .                        | 16        |
| High-confidence triggers . . . . .                                      | 7         | High-risk preventive configuration . . . . .                            | 17        |
| Weak signals that do not prove compromise by themselves . . . . .       | 7         | Apple account and sharing review — from a known-good platform . . . . . | 17        |
| <b>Operating Doctrine and Command Roles . . . . .</b>                   | <b>7</b>  | <b>Android . . . . .</b>                                                | <b>18</b> |
| GreyNOC operating principles . . . . .                                  | 7         | When compromise is suspected . . . . .                                  | 18        |
| Roles and decision rights . . . . .                                     | 8         | High-risk preventive configuration . . . . .                            | 18        |
| Escalation paths by leadership context . . . . .                        | 8         | Android replacement validation . . . . .                                | 18        |
| <b>Recognize and Declare the Incident . . . . .</b>                     | <b>9</b>  | <b>High-Risk Travel and Secure-Meeting Posture . . . . .</b>            | <b>19</b> |
| 1. Declare a working incident . . . . .                                 | 9         | Before travel . . . . .                                                 | 19        |
| 2. Ask the principal six questions . . . . .                            | 9         | During travel . . . . .                                                 | 19        |
| 3. Capture evidence without touching the phone . . . . .                | 9         | After travel or custody loss . . . . .                                  | 19        |
| <b>Contain and Preserve . . . . .</b>                                   | <b>10</b> | <b>Executive Mobile Readiness Baseline . . . . .</b>                    | <b>20</b> |
| 1. Establish physical custody . . . . .                                 | 10        | 90-day executive implementation plan . . . . .                          | 20        |
| 2. Preserve remote evidence immediately . . . . .                       | 10        | Quarterly leadership questions . . . . .                                | 21        |
| 3. Freeze destructive actions . . . . .                                 | 10        | Quarterly review record . . . . .                                       | 21        |
| <b>Protect Accounts, Authority, and Operations . . . . .</b>            | <b>11</b> | <b>Incident Record — Initial . . . . .</b>                              | <b>22</b> |
| 1. Stand up clean command communications . . . . .                      | 11        | <b>Incident Record — Exposure, Decisions, Handoff . . . . .</b>         | <b>23</b> |
| 2. Rotate access in priority order — from a known-good device . . . . . | 11        | <b>Leadership Decision Record and Return Authorization . . . . .</b>    | <b>24</b> |
| 3. Use phishing-resistant authentication . . . . .                      | 12        | <b>Authoritative Source Basis and Limitations . . . . .</b>             | <b>25</b> |
| <b>Scope the Adjacent Trust Network . . . . .</b>                       | <b>12</b> | <b>Publication QA/QC Record . . . . .</b>                               | <b>26</b> |
| Systems and relationships to review . . . . .                           | 12        |                                                                         |           |

# Read This First

This manual is written for a CEO, general or flag officer, senior official, chief of staff, executive protection lead, or incident commander who believes a mobile phone may be compromised. It is designed for use under pressure: the first pages tell the leader what to do; the later chapters tell security teams how to preserve, scope, investigate, and recover.

A suspected phone must be treated as a potentially hostile sensor and identity token until cleared. It may expose conversations, messages, location, contacts, calendars, authentication prompts, cloud sessions, and instructions issued in the leader's name. End-to-end encryption protects data in transit; it does not protect a message after a compromised endpoint can read the screen, microphone, keyboard, or notification stream.<sup>[1]</sup>

## AUTHORITY AND SCOPE

Organization-specific emergency, classified spill, COMSEC, counterintelligence, legal, privacy, records, and evidence procedures control. Do not use this guide to bypass policy. If human safety, active operations, or classified information is at risk, the responsible authority may override evidence-preservation preferences; record who made the decision, when, and why.

## How to use this manual

| Reader                                      | Start here                           | Then                                                                          |
|---------------------------------------------|--------------------------------------|-------------------------------------------------------------------------------|
| <b>Principal / leader</b>                   | 60-Second Executive Action Card      | Hand the manual to security. Do not investigate the device.                   |
| <b>Executive protection / duty officer</b>  | Containment Choice; Phase 2 custody  | Maintain custody and the witness log until the incident team assumes control. |
| <b>Chief of staff / executive assistant</b> | Phase 3 clean command communications | Counter-impersonation notice and decision log.                                |
| <b>Incident team (CISO / SOC / S6 / J6)</b> | Phases 1 through 6                   | Evidence preservation, scoping, investigation, recovery design.               |
| <b>Authorizing official</b>                 | Return-to-service gate               | Leadership Decision Record and Return Authorization.                          |

## What “known-good” means

A known-good device is security-controlled, fully updated, and not paired or synchronized with the suspect phone. It should not depend on the same potentially compromised session, browser profile, password manager unlock, messaging link, or recovery factor until the incident team confirms those elements are trustworthy.

## Emergency contact card — complete before issue

**Complete this card and store it off-device before the manual is issued.** An emergency contact list that lives only on the suspect phone is not available at the moment it is needed.

| Function                                       | Primary contact | Secure method |
|------------------------------------------------|-----------------|---------------|
| <b>Security Operations / Incident Response</b> |                 |               |
| <b>Executive Protection / Duty Officer</b>     |                 |               |
| <b>CIO / CISO / S6 / J6</b>                    |                 |               |
| <b>Legal / Privacy / Records</b>               |                 |               |

| Function                                | Primary contact | Secure method |
|-----------------------------------------|-----------------|---------------|
| COMSEC / CI / Classification authority  |                 |               |
| Carrier enterprise support              |                 |               |
| Mobile forensic provider (contracted)   |                 |               |
| Account PIN and port-out lock stored at |                 |               |

## 60-Second Executive Action Card

### DECISION RULE

You do not need proof before taking temporary protective action. The objective is continuity of command, protection of people and information, and evidence-preserving containment.

1

#### STOP SENSITIVE USE

Do not call, text, email, authenticate, browse, or discuss the suspicion near the device.

2

#### MOVE IT OUT OF THE DECISION SPACE

Place it screen-up on a clear surface outside secure discussions. Maintain physical control. Do not carry it into another sensitive meeting, vehicle, residence, or command post.

3

#### CALL FROM A KNOWN-GOOD CHANNEL

Contact security, executive protection, the duty officer, or S6/J6. Do not use the suspect phone to report the incident.

4

#### PRESERVE IT

Do not unlock, reboot, update, reset, delete, uninstall, scan, remove the SIM, connect a cable, or inspect settings unless the incident lead directs it.

5

#### SHIFT OPERATIONS

Move to an approved alternate device and channel. Tell a small need-to-know group that instructions from the old number, email, or messaging account require independent callback verification.

### Never do these on your own

#### DO NOT

Factory-reset the phone; remote-wipe it; install a "security" app; browse for spyware indicators; forward suspicious links from it; place it in a freezer, microwave, improvised metal box, or untested pouch; destroy it; or let an unvetted technician handle it.

### Immediate mission and safety exception

If the device may be actively recording a classified, privileged, life-safety, or operational discussion and trained help is not immediately available, the responsible leader may order it powered off after noting the time and circumstances. **Do not restart it.** This is a deliberate tradeoff: powering off may stop ongoing collection, but it can also destroy volatile evidence and trigger stronger authentication on restart.<sup>[8]</sup>

**LEADER SENTENCE**

*"My primary phone is out of service. Do not act on instructions from that number or its linked accounts until security revalidates them."*

## Containment Choice

*Preserve evidence without leaving the mission exposed.*

Mobile containment is a command decision, not a ritual. Current SWGDE mobile-evidence guidance warns that power loss, device-management changes, network interaction, SIM handling, incorrect passcode attempts, and peripherals can affect evidence. Airplane mode, shutdown, and RF isolation each trade remote-risk reduction against evidence and access: airplane mode requires interaction and may leave services active; shutdown can invoke stronger security and lose volatile state; and RF containers must be tested and managed for signal leakage and battery drain.<sup>[8]</sup>

| Situation                                                                                                                      | Preferred action                                                                                              | Why                                                                                              | Risk / control                                                                                             |
|--------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
| <b>Device is already powered off</b>                                                                                           | Leave it off. Secure it and tell the forensic lead its observed state.                                        | Avoids a boot that can change evidence, reconnect networks, and impose stronger access controls. | Do not attempt to charge, boot, or unlock it unless the qualified response team directs.                   |
| <b>Trained response team arriving within minutes</b>                                                                           | Leave the phone on and untouched; move it outside the sensitive space; maintain line of sight.                | Preserves device state and reduces unnecessary interaction.                                      | Do not unlock it. Do not connect power or accessories unless directed.                                     |
| <b>Validated RF isolation kit and trained handler available</b>                                                                | Place the phone in the tested isolation system and follow the organization's battery and transport procedure. | Reduces remote communication while preserving the device.                                        | Consumer pouches may leak. A phone searching for signal can drain its battery quickly.                     |
| <b>Immediate recording, exfiltration, remote-wipe, or safety risk outweighs volatile evidence; expert help is not imminent</b> | Authorized leader documents the time, powers the phone off, secures it, and does not restart it.              | Stops most active device functions and communications.                                           | May lose RAM evidence, trigger stronger authentication, and delay acquisition.                             |
| <b>Responder specifically directs airplane mode</b>                                                                            | Follow the exact sequence, document every touch, and verify all radios as directed.                           | Can reduce some network paths without a full shutdown.                                           | It changes evidence and may leave GPS, Wi-Fi, Bluetooth, or other services active. Not the leader default. |
| <b>Desire to remote-wipe "just in case"</b>                                                                                    | Do not wipe. Preserve cloud, MDM, identity, carrier, and device evidence first.                               | A wipe can destroy the strongest evidence and may not remediate accounts or carrier compromise.  | Only an authorized incident commander may approve a wipe for overriding safety or mission reasons.         |

**HANDS OFF**

Physical removal from the sensitive area, continuous custody, and a known-good call are safer defaults than experimenting with settings. The phone should not be trusted, but it should not be altered without a reason.

## Containment decision log

|                                                                         |  |
|-------------------------------------------------------------------------|--|
| Time suspicion was raised / time zone                                   |  |
| Device state (on / off / locked / unlocked / unknown) and battery shown |  |
| Location and sensitive activity underway                                |  |
| Containment decision and authority                                      |  |
| Every interaction with the device                                       |  |

## Threat Model

*What a compromised phone can become.*

A compromised mobile device is more than a bad computer. It sits at the intersection of identity, communications, location, social trust, and physical movement. Senior leaders are attractive targets because a single device can reveal both information and authority. CISA frames this population as highly targeted individuals in senior government, military, and political positions, and advises them to assume communications are at risk of interception or manipulation.<sup>[1]</sup>

## Mobile compromise exposure path

| Stage                                | What happens                                                                                                     | Leadership consequence                                                                       |
|--------------------------------------|------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------|
| <b>1. Targeting</b>                  | A leader, aide, family member, protection team, or trusted contact is selected.                                  | The adversary uses schedule, travel, relationships, public reporting, or previous access.    |
| <b>2. Access</b>                     | Exploit, malicious link, account theft, SIM attack, profile or app abuse, or physical access creates a foothold. | The visible symptom may be minor or nonexistent.                                             |
| <b>3. Control</b>                    | The attacker gains endpoint, account, carrier, or linked-device capabilities.                                    | Encrypted apps can no longer compensate for a hostile endpoint.                              |
| <b>4. Collection / impersonation</b> | Messages, microphone, camera, location, contacts, tokens, prompts, or instructions are observed or abused.       | Meetings, movements, relationships, and command intent may be exposed or forged.             |
| <b>5. Mission impact</b>             | Information is exploited, decisions are manipulated, or trust in communications is degraded.                     | Operational delay, fraud, extortion, reputational harm, intelligence loss, or physical risk. |

## Six hypotheses to test

| Hypothesis                                                                                   | Typical evidence sources                                                                                         | What not to assume                                                   |
|----------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------|
| <b>Endpoint exploit, RCE, or mercenary spyware</b>                                           | Vendor threat notice, forensic artefact, crash or telemetry correlation, exploit chain evidence, intrusion logs. | A clean consumer scan does not rule it out.                          |
| <b>Malicious or abused app, profile, certificate, accessibility service, or device admin</b> | Install history, MDM, app provenance, permissions, profiles, certificates, device policy.                        | An unfamiliar name alone is not proof.                               |
| <b>Cloud or identity account takeover</b>                                                    | Sign-in logs, session tokens, recovery changes, device lists, forwarding rules, OAuth grants.                    | The handset itself may be technically clean.                         |
| <b>Carrier, SIM, eSIM, or port-out compromise</b>                                            | Carrier records, SIM changes, call forwarding, number-port activity, service interruptions.                      | Changing the handset alone may not fix it.                           |
| <b>Telecommunications interception or manipulation</b>                                       | Carrier or network investigation, call-record anomalies, protocol exposure, infrastructure alerts.               | End-to-end encrypted apps reduce transit risk but not endpoint risk. |
| <b>Benign anomaly or false positive</b>                                                      | Known updates, battery health, VPN routing, legitimate admin action, normal app behaviour.                       | One strange symptom should not become attribution.                   |

**EVIDENCE DOCTRINE**

Do not accept the first frightening explanation, and do not accept the first reassuring explanation. Build a chain from independent evidence.

## Severity Without Panic

Severity is not the same as certainty. A weak technical signal can still require immediate action when the consequence is enormous. Use three factors: evidence confidence, operational consequence, and exposure window.

**RISK MODEL**

Operational severity = evidence confidence × consequence × exposure. The incident commander may raise severity because of classified access, imminent operations, physical safety, fiduciary authority, market-moving information, or public trust.

| Level           | Examples                                                                                                                                                                                                                                                    | Required response                                                                                                                                                    |
|-----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>CRITICAL</b> | High-confidence vendor threat notification; confirmed malicious artefact; unauthorized commands issued in the leader's name; evidence of microphone, camera, or location collection during sensitive activity; probable classified or life-safety exposure. | Stop use immediately. Activate executive incident command, legal, CI and COMSEC as applicable, replacement communications, evidence preservation, and broad scoping. |
| <b>HIGH</b>     | Credible targeted lure; unknown trusted device or session; unexplained MDM, profile, certificate, or admin change; SIM or eSIM change; physical custody loss; security alert correlated with suspicious activity.                                           | Contain and preserve now. Rotate priority accounts from a known-good platform. Plan clean replacement unless evidence quickly supports a benign cause.               |
| <b>MEDIUM</b>   | Unusual heat, battery drain, crashes, data use, pop-ups, or call quality; a single unknown sign-in with a plausible explanation.                                                                                                                            | Report, document, and triage. Do not self-diagnose or erase evidence. Raise severity if independent signals agree.                                                   |

| Level | Examples                                                                                                                              | Required response                                                                                |
|-------|---------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|
| LOW   | Known software update, expected travel sign-in, verified carrier change, documented administrator action, or resolved hardware issue. | Record the explanation and validation. Continue monitoring; do not force a compromise narrative. |

## High-confidence triggers

- An Apple threat notification verified by typing **account.apple.com** on a known-good device. Apple describes these as high-confidence alerts of individual targeting and says they should be taken very seriously.<sup>[2]</sup>
- A security-team or vendor finding tied to a specific device, account, exploit, profile, certificate, token, or malicious session.
- A confirmed carrier event, number port, SIM or eSIM change, or forwarding rule that the organization did not authorize.
- A command, payment, personnel action, disclosure, or message sent from the leader's identity that the leader did not issue.
- Evidence that the suspect phone was present during protected, classified, privileged, board, merger, financial, or operational planning activity.

## Weak signals that do not prove compromise by themselves

- Battery drain, heat, slow performance, random reboots, storage pressure, camera or microphone indicators, or an app crash.
- A foreign IP address, unusual geolocation, poor call quality, spam, an unfamiliar process label, or a single antivirus or MTD alert.
- A phone that behaves differently after an OS update, travel, roaming, a new VPN, new MDM policy, or cellular handoff.

# Operating Doctrine and Command Roles

## GreyNOC operating principles

| Principle                                | Operational meaning                                                                                                |
|------------------------------------------|--------------------------------------------------------------------------------------------------------------------|
| 1. Protect the decision space            | Remove the suspect device from sensitive discussions and movements.                                                |
| 2. Use a known-good channel              | Do not coordinate the response on the device or account under suspicion.                                           |
| 3. Preserve before changing              | Every unlock, reboot, update, scan, uninstall, reset, or cable connection may alter evidence.                      |
| 4. Separate device, account, and carrier | A replacement handset does not automatically fix compromised sessions, cloud accounts, forwarding, or SIM control. |
| 5. Facts before attribution              | State what happened and what evidence supports it; do not infer an actor or country from a symptom.                |
| 6. Mission can override forensics        | Safety and operations may require shutdown or wipe; document the authority and the tradeoff.                       |
| 7. Recover from trust, not hope          | High-consequence cases use clean hardware, clean enrolment, fresh credentials, and selective data restoration.     |
| 8. No self-clearance                     | The principal does not return a device or identity to service based on personal observation or one clean scan.     |



## Roles and decision rights

| Role                                              | Owns                                                                                                       | Must not do                                                                            |
|---------------------------------------------------|------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------|
| <b>Principal / leader</b>                         | Stop use; disclose relevant activity; approve continuity and mission decisions; support scoping.           | Investigate the phone, minimize facts, or resume use before clearance.                 |
| <b>Chief of staff / executive assistant</b>       | Alternate communications; need-to-know notice; calendar and contact exposure inventory; decision log.      | Send details through the suspect channel or broadly announce unverified compromise.    |
| <b>Executive protection / duty officer</b>        | Physical custody; secure-area removal; witness log; transport; immediate safety assessment.                | Experiment with consumer isolation products or connect accessories without procedure.  |
| <b>CISO / SOC / IR / S6 / J6</b>                  | Technical command; evidence plan; identity, MDM, carrier, cloud and network preservation; recovery design. | Issue a remote wipe before preservation and authorization.                             |
| <b>Legal / privacy / records / communications</b> | Privilege, notification, retention, regulatory, public messaging, board and governance obligations.        | Allow technical actions to outrun legal holds or disclosure requirements.              |
| <b>COMSEC / CI / classification authority</b>     | National-security, classified spill, hostile intelligence, insider-threat, and reporting procedures.       | Rely on this public guide in place of controlling directives.                          |
| <b>Carrier / platform / forensic specialist</b>   | Provider records, threat escalation, acquisition, analysis, and technical validation.                      | Receive unrestricted device access without authorization, scope, and chain of custody. |

## Escalation paths by leadership context

| Context                             | Notify immediately on a known-good channel                                                                                                                | Protect authority and operations                                                                                                                                                                                                           |
|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>CEO / corporate principal</b>    | CISO or incident commander; general counsel; executive protection or corporate security; CIO, IAM and telecom; chief of staff.                            | Require independent callback for payments, M&A, board, personnel, market-sensitive, legal, and public instructions. Counsel determines board, insurer, regulator, law-enforcement, and disclosure obligations from verified facts.         |
| <b>Military / command principal</b> | Chain or duty officer; S6/J6 and designated cyber response or CSSP; security manager; CI and COMSEC when indicated; legal and public affairs as directed. | Remove the device from classified and controlled spaces, invoke spill, OPSEC and COMSEC reporting as applicable, establish an approved alternate command channel, and assess affected units, mission partners, movements, and authorities. |

### MILITARY OVERLAY

If the phone carried, displayed, discussed, photographed, or was present around classified or controlled information, immediately invoke the organization's classified spill, OPSEC, COMSEC, counterintelligence, security-manager, and command-reporting procedures. **This manual contains no classified handling instructions.**

## PHASE 1

# Recognize and Declare the Incident

The first objective is not to prove malware. It is to determine whether temporary protective action is justified and to establish a reliable starting record. NIST SP 800-61 Rev. 3 provides the wider incident-response lifecycle this manual sits inside.<sup>[7]</sup>

## 1. Declare a working incident

Use neutral language: *suspected mobile compromise* or *suspected account or device security event*. Avoid announcing spyware, nation-state activity, or attribution until evidence supports the claim.

- Assign an incident ID, incident commander, scribe, technical lead, and executive liaison.
- Record the date, time zone, location, event that triggered concern, device state, and who first observed it.
- Mark facts, reports, inferences, and decisions separately. Record uncertainty rather than hiding it.
- Establish a need-to-know distribution list and an approved alternate channel.

## 2. Ask the principal six questions

| Question                                                                                                       | Why it matters                                                                |
|----------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------|
| <b>What exactly happened, and what did you see or hear?</b>                                                    | Captures the original observation before it is influenced by troubleshooting. |
| <b>When was the last time the phone was known to behave normally?</b>                                          | Establishes the initial scoping window.                                       |
| <b>Was the phone unlocked, handled by another person, repaired, searched, seized, lost, or out of sight?</b>   | Tests physical-access and custody hypotheses.                                 |
| <b>Did you open a link, attachment, calendar invitation, profile prompt, sign-in request, or unusual call?</b> | Identifies potential delivery paths without blaming the user.                 |
| <b>What sensitive meetings, travel, decisions, credentials, or communications occurred during the window?</b>  | Measures operational consequence and exposure.                                |
| <b>What other devices and accounts are paired, linked, or used for recovery?</b>                               | Defines the adjacent trust network.                                           |

## 3. Capture evidence without touching the phone

- Use an external camera to photograph the screen, visible time, battery, signal indicators, notifications, device condition, and surrounding context. Do not screenshot from the suspect phone.<sup>[8]</sup>
- Preserve the original suspicious message or alert from server-side systems, another recipient, email security, messaging administration, or a known-good linked record where possible.
- Record whether the phone is on, off, locked, or unlocked. If it is already unlocked, do not navigate; tell the forensic lead immediately.
- Identify the number, device model, serial, IMEI, eSIM and carrier from inventory, MDM, procurement, or carrier records rather than opening device settings.

**DO NOT PROVE COMPROMISE ON THE COMPROMISED DEVICE**

Browsing menus, installing tools, opening the suspicious message, searching the web, or running a scan creates new artefacts and may alert an adversary.

**PHASE 2**

## Contain and Preserve

### 1. Establish physical custody

1. Move the device outside the sensitive area. Keep it away from ongoing meetings, vehicles, bedrooms, secure workspaces, and other leaders.
2. Assign one custodian and one witness. Record every transfer with date, time, location, names, device state, and seal or container identifier.
3. Do not allow the phone to auto-pair with vehicles, headsets, watches, computers, conference systems, or charging stations.
4. Use only validated evidence packaging and transport procedures. Do not rely on improvised shielding.
5. Deliver the device to a qualified mobile forensic or incident-response team as soon as practical.

### 2. Preserve remote evidence immediately

Device preservation and cloud containment should proceed in parallel. From known-good administrative systems, preserve before logs roll over or an attacker removes evidence.

| Source                         | Preserve                                                                                                 | Owner                           |
|--------------------------------|----------------------------------------------------------------------------------------------------------|---------------------------------|
| <b>Identity provider / SSO</b> | Sign-ins, device trust, MFA changes, token issuance, session and risk events, admin actions.             | IAM / SOC                       |
| <b>Email and collaboration</b> | Mailbox audit, forwarding, inbox rules, delegate access, OAuth grants, message trace, shared files.      | Messaging / cloud admin         |
| <b>MDM / MTD / EDR</b>         | Enrolment, compliance, app inventory, configuration changes, alerts, device commands, last check-in.     | Endpoint team                   |
| <b>Apple / Google account</b>  | Device list, security events, recovery changes, trusted numbers, app access, linked sessions.            | IR with principal               |
| <b>Carrier</b>                 | SIM and eSIM events, ports, forwarding, account changes, support contacts, number and device history.    | Telecom manager                 |
| <b>Messaging apps</b>          | Linked desktops and tablets, group membership, safety-number or key changes where available, admin logs. | Service owner                   |
| <b>Network / DNS / Wi-Fi</b>   | Authentication, VPN, DNS, proxy, secure web gateway, wireless association, travel-network logs.          | Network team                    |
| <b>Physical security</b>       | Access logs, visitor records, CCTV, repair, cleaning and transport records, hotel or venue custody.      | Executive protection / security |

### 3. Freeze destructive actions

| State-changing action        | Why it is normally prohibited before approval                                                 |
|------------------------------|-----------------------------------------------------------------------------------------------|
| <b>Unlocking or browsing</b> | Changes timestamps, app state, notifications and caches, and may trigger malicious behaviour. |

| State-changing action                               | Why it is normally prohibited before approval                                                                |
|-----------------------------------------------------|--------------------------------------------------------------------------------------------------------------|
| Rebooting or powering off                           | May destroy volatile memory and require stronger authentication on restart.                                  |
| Updating OS or apps                                 | Replaces binaries and logs, changes exploitability, and can obscure the original state.                      |
| Deleting an app, profile, or certificate            | Removes evidence and may not remove persistence or account access.                                           |
| Running antivirus, MTD, or consumer spyware checks  | Adds artefacts; a negative result cannot certify absence of sophisticated compromise.                        |
| Removing SIM or eSIM, or inserting another SIM      | Changes state and may affect network records or device behaviour.                                            |
| Factory reset or remote wipe                        | Destroys evidence; does not independently remediate cloud, carrier, linked-device, or credential compromise. |
| Connecting a cable, charger, computer, or accessory | Creates trust relationships and may expose another system; power decisions belong to trained responders.     |

**EVIDENCE PRIORITY**

Preserve first. Isolate by an approved method. Eradicate only after the incident commander understands what evidence will be lost.

**PHASE 3**

## Protect Accounts, Authority, and Operations

Assume the phone may expose both content and the ability to approve actions. The fastest safe response is to move authority to a clean communications path and then revoke the suspect identity's access in a controlled order.

### 1. Stand up clean command communications

1. Issue an organization-managed replacement or loaner that was provisioned from trusted inventory and is **not** restored from the suspect device's full backup.
2. Use an approved end-to-end encrypted channel when policy permits, but remember that endpoint integrity still controls trust.<sup>[1]</sup>
3. Create a temporary callback rule: material instructions, payments, personnel changes, movement orders, disclosures, or public statements require a second channel and an established verifier.
4. Brief only the people who must prevent impersonation: chief of staff, aide, executive protection, finance, legal, communications, operations centre, and designated family or security contacts as justified.
5. Do not broadcast detailed indicators, travel, or sensitive incident facts to a broad distribution list.

**SAMPLE NOTICE**

*"My primary mobile device and its linked number and accounts are under security review. Until formally cleared, do not act on instructions from them without callback to the approved alternate number and verifier."*

### 2. Rotate access in priority order — from a known-good device

| Priority                | Action                                                                                                                     | Control point                                                                |
|-------------------------|----------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------|
| 1. Identity, email, SSO | Change credentials, revoke sessions and tokens, remove unknown devices, keys, recovery methods, delegates, and forwarding. | Use alternate trusted factors; do not send reset codes to the suspect phone. |

| Priority                                                       | Action                                                                                                              | Control point                                                                           |
|----------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|
| <b>2. Password manager</b>                                     | Change the master credential, rotate recovery methods, review trusted devices and emergency access.                 | Treat stored credentials as potentially exposed if the vault was unlocked on the phone. |
| <b>3. Carrier</b>                                              | Set or change the account PIN, port-out lock, and high-risk handling note; review SIM, eSIM and forwarding history. | Do not rely on SMS as the only recovery method.                                         |
| <b>4. Messaging and collaboration</b>                          | Revoke linked devices and web sessions, review group membership and key changes, revalidate sensitive contacts.     | Notify participants through a separate verified path.                                   |
| <b>5. Cloud and business systems</b>                           | Revoke mobile sessions and app passwords; rotate privileged credentials and signing or approval mechanisms.         | Prioritize systems tied to fiduciary, personnel, operational, or public authority.      |
| <b>6. Financial, social, and personal high-impact accounts</b> | Change credentials, recovery channels, trusted devices, API and app access, and transaction controls.               | Coordinate with legal, finance, family office, and protection teams as appropriate.     |

### 3. Use phishing-resistant authentication

CISA recommends phishing-resistant MFA for highly targeted users, with hardware FIDO security keys as the strongest practical option and passkeys as an acceptable alternative. SMS and voice codes remain vulnerable to phishing, signalling attacks, and SIM takeover.<sup>[1]</sup>

- Maintain at least two security keys where the platform requires a backup; store them separately under controlled custody.
- Remove unknown passkeys, keys, trusted devices, recovery emails, phone numbers, OAuth apps, and application passwords.
- Do not enrol a new factor on a suspect device or from a suspect browser session.
- Document which credentials, sessions, certificates, signing keys, and approvals were rotated and which remain outstanding.

## PHASE 4

## Scope the Adjacent Trust Network

The suspect phone rarely stands alone. Scope every system that trusted it and every person who could be used to regain access or impersonate the leader. Keep the scope proportionate, authorized, and need-to-know.

### Systems and relationships to review

| Category                         | Examples                                                                                             | Key question                                                                          |
|----------------------------------|------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| <b>Paired and linked devices</b> | Watch, tablet, laptop, vehicle, headset, desktop messaging client, smart display.                    | Could it receive messages, calls, notifications, tokens, location, or account access? |
| <b>Recovery and trust paths</b>  | Backup email, phone number, recovery contact, family account, assistant, delegate, emergency access. | Could an attacker reset or re-enrol the account through this path?                    |
| <b>Executive support network</b> | Aides, chief of staff, protection team, household or family office, board support, finance staff.    | Did they receive unusual requests, links, sign-ins, or changes?                       |

| Category                             | Examples                                                                                                 | Key question                                                                      |
|--------------------------------------|----------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| <b>Physical access chain</b>         | Repair vendor, hotel, vehicle service, screening point, conference staff, cleaning, courier, visitor.    | When and where was the device outside trusted custody?                            |
| <b>Sensitive operational context</b> | Board sessions, M&A, earnings, negotiations, travel, troop movement, crisis response, legal strategy.    | What could microphone, camera, calendar, location, or notification access reveal? |
| <b>Data synchronization</b>          | Cloud backup, photos, notes, contacts, calendars, browser sync, password sync, health and location data. | What information replicated beyond the handset?                                   |

## Counter-impersonation controls

- Require callback to a pre-established number for material decisions.
- Use a verbal verifier or challenge process that is not stored in the suspect phone or message history.
- Temporarily suspend one-person approval for payments, public statements, movement, access grants, personnel actions, or emergency exceptions.
- Tell recipients not to trust a familiar writing style, voice note, video, contact card, caller ID, or existing message thread by itself.
- Preserve suspicious instructions and recipient reports; do not challenge the suspected attacker from the compromised channel.

## Exposure review for meetings and movements

| Exposure                                   | Review window                                                                           | Protective action                                                                     |
|--------------------------------------------|-----------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| <b>Microphone / room audio</b>             | From the last known-good time through containment.                                      | Identify sensitive meetings, calls, vehicles, residences, and informal conversations. |
| <b>Camera / screen / document</b>          | Times the phone faced documents, whiteboards, screens, facilities, badges, or people.   | Assess photographed or observed content and physical-security consequences.           |
| <b>Location / travel</b>                   | Routes, hotels, venues, residences, bases, visits, patterns.                            | Protect future movement, contacts, and recurring locations.                           |
| <b>Calendar / contacts / notifications</b> | Scheduled and recent events; new contacts; preview content.                             | Warn exposed parties proportionately and re-plan sensitive engagements.               |
| <b>Authentication and approvals</b>        | Prompts, codes, biometric unlocks, password-manager use, signing or transaction events. | Revoke sessions and rotate the highest-impact credentials first.                      |

### SCOPE DISCIPLINE

Do not automatically search the personal devices or accounts of staff, family, or contacts. Use legal authority, consent, policy, and documented necessity.

## PHASE 5

## Investigate, Correlate, and Decide

The investigation must answer two separate questions: what happened to the device or identity, and what information or authority may have been exposed. A technically inconclusive device can still produce a high-consequence operational incident.

### Investigation workstreams

| Workstream                      | Core questions                                                                             | Evidence                                                                                                                  |
|---------------------------------|--------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
| <b>Device forensics</b>         | What executed, changed, persisted, communicated, or accessed sensitive sensors or data?    | Acquisition, system and app logs, crash data, install, profile and certificate history, intrusion logs where pre-enabled. |
| <b>Identity and cloud</b>       | Who signed in, from where, with what factor or token, and what changed?                    | Provider security events, tokens, recovery, device trust, OAuth, forwarding, mailbox and file audit.                      |
| <b>Carrier and telecom</b>      | Was the number, SIM, eSIM, forwarding, port, call or message path altered?                 | Carrier records, enterprise portal, support logs, signalling and network investigation.                                   |
| <b>Enterprise control plane</b> | Did MDM, MTD, EDR, VPN, DNS, proxy, Wi-Fi, or admin policy observe or cause the event?     | Central logs, commands, policy changes, network telemetry, administrator activity.                                        |
| <b>Physical and human</b>       | Who had access, what lure or social engineering occurred, and what did recipients observe? | Interviews, access, CCTV and repair records, suspicious messages, support tickets, travel events.                         |
| <b>Operational impact</b>       | What decisions, conversations, movements, credentials, or protected data were exposed?     | Calendar, meeting list, contact graph, transaction and command records, principal interview.                              |

### Evidence standards

| Assessment           | Meaning                                                                                                     | Required wording                                                                                       |
|----------------------|-------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------|
| <b>CONFIRMED</b>     | Direct, reproducible, or provider-validated evidence establishes the event.                                 | <i>"Evidence confirms..."</i> State the artefact and validation.                                       |
| <b>PROBABLE</b>      | Multiple independent indicators support one explanation and plausible alternatives are weaker.              | <i>"The available evidence makes it probable that..."</i>                                              |
| <b>POSSIBLE</b>      | Some evidence is consistent with the hypothesis, but alternatives remain material.                          | <i>"The evidence is consistent with, but does not establish..."</i>                                    |
| <b>NOT SUPPORTED</b> | The reviewed evidence does not support the hypothesis within the stated scope and limits.                   | Do not say <i>impossible</i> or <i>guaranteed clean</i> . State what was examined and the limitations. |
| <b>INCONCLUSIVE</b>  | Acquisition, logging, time, encryption, device state, or evidence quality prevents a defensible conclusion. | State the gap and choose recovery based on consequence, not reassurance.                               |

#### NEGATIVE SCAN LIMITATION

No single antivirus, mobile threat defence, app-store check, or forensic tool can prove the absence of every sophisticated exploit or spyware family. Clearance is a risk decision supported by evidence, scope, and recovery controls.

## Timeline anchors

- Last known-good device and account state.
- First suspicious message, call, crash, notification, sign-in, SIM event, physical custody gap, or user report.
- Sensitive meetings, travel, approvals, password-manager access, and authentication events during the window.
- Containment, session revocation, credential rotation, carrier action, acquisition, and recovery milestones.
- The point at which suspicious activity demonstrably stopped — and whether the cause was actually removed.

## PHASE 6

# Recover From a Known-Good Platform

Recovery is not the act of making the old phone look normal. It is the controlled restoration of trusted communications, identity, data, and authority. High-consequence incidents should favour replacement over attempted cleaning.

## Recovery tiers

| Tier                                                                      | Use when                                                                                                                                                 | Minimum recovery                                                                                                                                                                                    |
|---------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>A — Explained, low residual risk</b>                                   | Evidence supports a benign cause; no meaningful custody, identity, carrier, or high-risk exposure remains.                                               | Correct the cause, update, validate accounts and carrier, document the explanation, and monitor.                                                                                                    |
| <b>B — Credible targeted event, or inconclusive with high consequence</b> | A targeted lure, unknown access, custody gap, profile or session anomaly, or limited evidence leaves material doubt.                                     | New or freshly managed device, clean enrolment, new credentials and sessions, carrier review, selective data restore, enhanced monitoring.                                                          |
| <b>C — Confirmed or critical compromise</b>                               | Endpoint, account, carrier, or impersonation compromise is confirmed or probable, or classified and life-safety consequence demands zero residual trust. | New hardware and eSIM or SIM as directed; full identity and session reset; key replacement; linked-device and adjacent-account review; forensic retention of old equipment; executive revalidation. |

## Clean provisioning standard

NIST SP 800-124 Rev. 2 provides the enterprise mobile-management baseline these steps assume.<sup>[12]</sup>

1. Use current, supported hardware from trusted inventory with the latest approved operating system and firmware.
2. Enrol through the organization's MDM before sensitive use; apply device compliance, secure DNS or VPN where required, application allowlisting, and logging controls.
3. Create or re-enrol credentials and phishing-resistant factors from known-good systems. Revoke all prior sessions and unknown keys.
4. Install only required, approved applications from official stores or managed distribution.
5. Do not restore a full image or settings backup from the suspect phone by default. Restore selected contacts, photos, messages, and files only after the incident team evaluates the risk and business need.
6. Re-establish messaging groups and verify critical contacts and encryption or safety keys through an independent channel.
7. Keep the suspect device, SIM and eSIM records, packaging, and acquisition artefacts under retention or evidence procedures.



## Return-to-service gate

|                          |                                                                                                                      |
|--------------------------|----------------------------------------------------------------------------------------------------------------------|
| <input type="checkbox"/> | Hardware and OS are supported, fully updated, and organization-owned or approved.                                    |
| <input type="checkbox"/> | MDM and endpoint controls show healthy enrolment and the correct policy set.                                         |
| <input type="checkbox"/> | Identity, email, cloud, messaging, password manager, carrier, and recovery paths were reviewed and revalidated.      |
| <input type="checkbox"/> | Unknown devices, sessions, passkeys, security keys, profiles, certificates, forwarding, and app access were removed. |
| <input type="checkbox"/> | Priority credentials and approval mechanisms were rotated; backup factors are controlled.                            |
| <input type="checkbox"/> | No unreviewed full backup or unapproved application was restored.                                                    |
| <input type="checkbox"/> | Operational contacts received the new verified channel and the counter-impersonation rule.                           |
| <input type="checkbox"/> | Forensic, legal, privacy, records, CI, COMSEC, and leadership approvals are complete as applicable.                  |
| <input type="checkbox"/> | A 30-day monitoring and review plan is assigned.                                                                     |

### NO SELF-CLEARANCE

The leader does not resume use because the replacement “looks normal” or because one tool found nothing. The designated authorizing official owns the return decision.

## PLATFORM PLAYBOOK

# iPhone

## When compromise is suspected

- Follow the 60-Second Executive Action Card. Do not use the suspect iPhone to verify an alert, change settings, enable Lockdown Mode, run Safety Check, or alter the Apple Account unless the incident lead directs it.
- Preserve the original notification, associated email, time, device inventory, MDM records, and Apple Account security events. Treat a verified Apple threat notification as a **CRITICAL** trigger.
- Use expert assistance. Apple recommends that notified users obtain specialist help and enable Lockdown Mode as part of protection, and names the Digital Security Helpline operated by the nonprofit Access Now, reachable 24 hours a day, seven days a week.<sup>[2]</sup>

## Verifying an Apple threat notification

Apple delivers a threat notification through three channels at once. Confirm at least one of them from a known-good device before treating the alert as genuine, and confirm none of them asks you to take an action.

| Channel                   | What genuine looks like                                                                                                         | Verification step                                                                                                         |
|---------------------------|---------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
| <b>On the iPhone</b>      | An Apple Threat Notification alert appears on the Lock Screen and in Settings.                                                  | Photograph it with an external camera. Do not tap it.                                                                     |
| <b>Email</b>              | Sent to addresses associated with the Apple Account. As of 2026, Apple sends from <b>threat-notifications@email.apple.com</b> . | Check the sender from a known-good device. A different sender address is a phishing indicator, not a threat notification. |
| <b>Apple Account page</b> | A banner is displayed at the top of the account page after sign-in.                                                             | On a known-good device, <b>type</b> account.apple.com manually and sign in. Do not follow a link.                         |

**AUTHENTICITY RULE**

A genuine Apple threat notification never asks the user to click a link, open a file, install an app or profile, or provide an Apple Account password or verification code by email or on the phone. Any message that does any of those things is an attack, and should be preserved and reported as one.<sup>[2]</sup>

**High-risk preventive configuration**

| Control                                | Executive standard                                                                                                                                                                                                                                                                            | Important caveat                                                                                                                                                     |
|----------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Lockdown Mode</b>                   | For highly targeted leaders, enable on the clean or replacement iPhone: Settings > Privacy & Security > Lockdown Mode. It limits attachment types, link previews, complex web technology, unsolicited Apple-service invitations, accessory connections, and profile enrolment. <sup>[3]</sup> | It is preventive hardening, not proof of compromise and not a substitute for response. Enabling it changes device state; do not do so on evidence without direction. |
| <b>Apple Account security keys</b>     | Use at least two FIDO-certified keys, stored separately, for leaders who can support the recovery and custody model. <sup>[9]</sup>                                                                                                                                                           | Loss of every trusted device and security key can cause permanent account lockout. Plan custody and backup before enrolment.                                         |
| <b>Stolen Device Protection</b>        | Enable on executive devices to add biometric and security-delay protections around sensitive account and device changes. <sup>[14]</sup>                                                                                                                                                      | Does not replace strong passcodes, physical custody, or incident response.                                                                                           |
| <b>Strong passcode and lock screen</b> | Use the organization's strongest practical passcode standard; hide sensitive notification previews; minimize lock-screen functions.                                                                                                                                                           | Biometrics are convenient but are not a substitute for passcode governance and travel or legal planning.                                                             |
| <b>Updates and supported hardware</b>  | Enable automatic updates and verify weekly. Use current supported hardware capable of receiving the latest security features. <sup>[1]</sup>                                                                                                                                                  | Do not update a suspect evidence device before acquisition unless authorized.                                                                                        |
| <b>App and profile discipline</b>      | Use the App Store or managed distribution; keep the app set minimal; prohibit unapproved configuration profiles, certificates, VPNs, and MDM. <sup>[16]</sup>                                                                                                                                 | Unknown items must be reviewed by security, not deleted by the principal.                                                                                            |

**Apple account and sharing review — from a known-good platform**

- Review Apple Account devices, trusted phone numbers, recovery contacts, security keys, sign-in activity, and inactive devices. Remove unknown access after evidence preservation.<sup>[15]</sup>
- Review iPhone Mirroring, shared albums, calendars, notes, Find My and location sharing, Family Sharing, and other synchronized access relevant to the exposure.
- Safety Check can review and stop sharing, review connected devices, reset app privacy permissions, and change account and passcode settings on iOS 16 or later. Use it after evidence preservation, or immediately when personal safety overrides forensic concerns.<sup>[10]</sup>

## PLATFORM PLAYBOOK

# Android

## When compromise is suspected

- Follow the 60-Second Executive Action Card. Do not unlock and browse device-admin apps, accessibility services, certificates, VPNs, profiles, or permissions on the suspect phone unless directed.
- Preserve Google Account security events, device list, sessions, app access, recovery changes, Play Protect and enterprise alerts, MDM records, carrier events, and any pre-enabled Intrusion Logging records.
- If Intrusion Logging was already enabled, the incident team can obtain and decrypt the logs from a known-good Android device signed into the account. Do not alter the suspect device simply to turn logging on after the incident.<sup>[5]</sup>
- For a high-consequence targeted event, use a clean replacement rather than relying on a reset and one clean scan.

## High-risk preventive configuration

| Control                                           | Executive standard                                                                                                                                                                                                                                                                            | Important caveat                                                                                                                            |
|---------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Android Advanced Protection — device</b>       | On supported devices, open Settings > Security & privacy > Advanced Protection and enable device protection. It enforces multiple protections, including Play Protect, blocking unknown-source apps, safer browsing, USB and network safeguards, and other hardening features. <sup>[4]</sup> | Availability and exact protections vary by device, OS version, region, and managed policy. Enabling it may require a restart.               |
| <b>Intrusion Logging</b>                          | Where supported, enable in advance under Advanced Protection. It records selected app, install, network, USB, certificate, and lock or unlock events; data is end-to-end encrypted and stored for 12 months. <sup>[5]</sup>                                                                   | Downloaded logs are sensitive. Store and transfer them under evidence controls. Access depends on account and screen-lock recovery factors. |
| <b>Google Account Advanced Protection Program</b> | Enrol high-risk work and personal Google Accounts where supported. It requires passkeys or security keys, restricts third-party access, applies stronger download checks, and tightens recovery. <sup>[6]</sup>                                                                               | Prepare recovery information and primary and backup keys before enrolment. Workspace support depends on administration.                     |
| <b>Updates and hardware support</b>               | Use models with strong hardware-backed security and long, documented update commitments. Enable automatic updates and verify current patch status weekly. <sup>[1]</sup>                                                                                                                      | Do not update a suspect evidence device before acquisition unless authorized.                                                               |
| <b>Play Protect and app provenance</b>            | Keep Play Protect enabled; prohibit sideloading and unknown app stores unless a documented enterprise need is approved.                                                                                                                                                                       | A Play Protect result does not clear a sophisticated targeted incident.                                                                     |
| <b>Permissions and special access</b>             | Minimize camera, microphone, location, accessibility, notification, device-admin, VPN, certificate, and install-unknown-apps privileges.                                                                                                                                                      | Review on clean baseline devices or under incident-team direction; do not delete evidence on the suspect phone.                             |
| <b>Network hardening</b>                          | Keep 2G disabled where supported, use organization-approved secure DNS or VPN, avoid untrusted Wi-Fi, and do not pair rental cars or unknown accessories.                                                                                                                                     | Coverage and emergency requirements may require documented exceptions.                                                                      |

## Android replacement validation

- Confirm bootloader and device integrity state under the organization's management tooling.

- Confirm no unknown device-admin app, accessibility service, VPN, CA certificate, work profile, private DNS, notification listener, or account remains.
- Confirm Play Protect, Advanced Protection, screen lock, anti-theft features, MDM, application policy, logging, and update settings are active.
- Re-enrol passkeys or hardware keys only from the clean device and revoke prior sessions, recovery paths, and app access.
- Restore selected content only after review; do not automatically copy the full suspect device state.

## High-Risk Travel and Secure-Meeting Posture

Travel, public events, hostile intelligence environments, political activity, negotiations, crises, and high-value corporate transactions increase both targeting and the cost of a missed incident. Use a travel posture that assumes the device may leave normal physical and network controls. The UK NCSC guidance for high-risk individuals is a useful companion briefing for principals and their staff. <sup>[11]</sup>

### Before travel

- Issue a travel device with minimal data, minimal apps, separate managed accounts where appropriate, and a defined post-travel disposition.
- Apply current patches, high-risk platform protections, MDM policy, secure DNS or VPN as required, phishing-resistant MFA, and carrier port and SIM controls.
- Remove unnecessary documents, message history, credentials, photos, notes, contacts, and synchronized services.
- Store backup security keys separately; do not carry every recovery factor together.
- Brief the leader, aide, and protection team on custody, inspection and seizure reporting, suspicious prompts, device exclusion, charging, pairing, and alternate communications.

### During travel

- Maintain continuous custody. Report any loss of sight, inspection, repair, unlock request, seizure, swap, or unexpected restart.
- Do not pair with rental vehicles, hotel televisions, conference systems, kiosks, unknown headsets, or unapproved computers.
- Use approved chargers and cables; avoid data connections to public charging or unknown accessories.
- Keep phones, watches, earbuds, tablets, and smart accessories out of sensitive meetings unless specifically authorized.
- Treat unexpected MFA prompts, profile or certificate requests, SIM loss, service changes, account-recovery messages, and targeted invitations as reportable events.

### After travel or custody loss

| Condition                                                                                    | Required action                                                                                                                |
|----------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------|
| <b>Device remained in approved custody with no anomaly</b>                                   | Complete post-travel check-in, account and security-event review, update verification, and MDM compliance review.              |
| <b>Device was inspected, unlocked, repaired, connected, or out of sight</b>                  | Do not reconnect to sensitive systems until security review. Consider Tier B replacement based on environment and consequence. |
| <b>Targeted lure, threat notification, account or telecom anomaly, or credible tampering</b> | Activate the full incident guide and treat as HIGH or CRITICAL.                                                                |

| Condition                                                 | Required action                                                                                  |
|-----------------------------------------------------------|--------------------------------------------------------------------------------------------------|
| <b>Travel device was designed for disposal or rebuild</b> | Preserve any incident evidence, then execute the approved clean-return or destruction procedure. |

#### SECURE MEETING RULE

A phone outside the room is safer than a muted phone on the table. Device exclusion must include wearables and linked accessories when the meeting warrants it.

## Executive Mobile Readiness Baseline

The response will fail under pressure unless the organization prepares the people, spare equipment, authorities, and recovery factors in advance. The following baseline should be owned jointly by security, executive protection, IT, legal, and the principal's staff.

|                          |                                                                                                                                                                                                    |
|--------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <input type="checkbox"/> | <b>Contacts</b> — 24/7 security and IR, duty officer, CISO or S6/J6, legal and privacy, CI and COMSEC, carrier, platform and forensic contacts are printed and available off-device.               |
| <input type="checkbox"/> | <b>Alternate channel</b> — A known-good replacement or loaner and an approved secure channel can be issued without relying on the suspect phone.                                                   |
| <input type="checkbox"/> | <b>Identity resilience</b> — Two or more phishing-resistant factors are available where needed; recovery factors are separated and tested.                                                         |
| <input type="checkbox"/> | <b>Carrier controls</b> — Account PIN, port-out lock, enterprise escalation, authorized contacts, and SIM and eSIM inventory are current.                                                          |
| <input type="checkbox"/> | <b>Managed baseline</b> — Current hardware, automatic updates, weekly patch verification, MDM and MTD, minimal apps, strong passcode, hidden previews, and approved network controls are enforced. |
| <input type="checkbox"/> | <b>High-risk mode</b> — Lockdown Mode or Android Advanced Protection is evaluated and enabled for the appropriate threat profile.                                                                  |
| <input type="checkbox"/> | <b>Forensic readiness</b> — Provider-log retention, MDM and identity audit, chain-of-custody supplies, validated RF isolation, and a qualified mobile forensic capability are available.           |
| <input type="checkbox"/> | <b>Travel posture</b> — Travel devices, minimal-data profiles, custody rules, inspection reporting, charger and pairing rules, and post-travel review are documented.                              |
| <input type="checkbox"/> | <b>Impersonation defence</b> — Callback, verifier, dual-approval, and emergency notice procedures are practised by aides, finance, communications, operations, and protection staff.               |
| <input type="checkbox"/> | <b>Exercise</b> — Leadership and staff complete a tabletop at least annually and after material platform, threat, or organizational changes.                                                       |

## 90-day executive implementation plan

| Time                 | Minimum action                                                                                                                                      |
|----------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>First 7 days</b>  | Complete contacts; carrier controls; device and account inventory; update verification; strong passcodes; session review; replacement-channel plan. |
| <b>First 30 days</b> | Deploy phishing-resistant MFA; high-risk platform controls; managed app baseline; provider-log retention; clean loaner; callback and dual approval. |
| <b>First 60 days</b> | Contract or validate mobile forensic support; test RF isolation equipment; build travel profiles; exercise account and carrier recovery.            |

| Time          | Minimum action                                                                                                            |
|---------------|---------------------------------------------------------------------------------------------------------------------------|
| First 90 days | Run a CEO or commander tabletop, correct gaps, approve the return-to-service authority matrix, schedule quarterly review. |

## Quarterly leadership questions

- Could we replace the principal's phone and restore trusted communications within one hour without using the suspect device?
- Do we know every account, device, number, delegate, recovery path, and linked application that can act in the principal's name?
- Can we preserve identity, carrier, MDM, messaging, and cloud evidence before it expires?
- Who can order shutdown, isolation, wipe, public disclosure, classified reporting, and return to service?
- Have the principal, aide, and protection team practised the first five minutes?

## Quarterly review record

| Quarter / date | Review lead | Status              | Priority corrective action |
|----------------|-------------|---------------------|----------------------------|
| Q1             |             | Green / Amber / Red |                            |
| Q2             |             | Green / Amber / Red |                            |
| Q3             |             | Green / Amber / Red |                            |
| Q4             |             | Green / Amber / Red |                            |

## WORKSHEET 1 OF 3

# Incident Record — Initial

**USE**

Complete from a known-good system or on paper. **Do not type incident notes into the suspect phone.**

|                                                    |  |
|----------------------------------------------------|--|
| Incident ID                                        |  |
| Date / time / time zone                            |  |
| Principal / role                                   |  |
| Incident commander                                 |  |
| Scribe / executive liaison                         |  |
| Trigger — exact words and observation              |  |
| Device make / model / number / asset ID            |  |
| State when observed (on / off / locked / unlocked) |  |
| Visible battery / signal / notifications           |  |
| Location and activity underway                     |  |
| Last known-good time                               |  |
| First suspected event                              |  |
| Physical custody gaps / repair / inspection        |  |

## WORKSHEET 2 OF 3

## Incident Record — Exposure, Decisions, Handoff

|                                                     |  |
|-----------------------------------------------------|--|
| <b>Sensitive meetings / conversations in window</b> |  |
| <b>Travel / locations / facilities in window</b>    |  |
| <b>Accounts and linked devices</b>                  |  |
| <b>Credentials / password manager / MFA used</b>    |  |
| <b>Suspect messages, links, calls, invitations</b>  |  |
| <b>Containment action, time, and authority</b>      |  |
| <b>Known-good channel issued</b>                    |  |
| <b>Counter-impersonation notice recipients</b>      |  |
| <b>Sessions / credentials / carrier actions</b>     |  |
| <b>Evidence preserved and by whom</b>               |  |
| <b>Chain-of-custody transfers / seal IDs</b>        |  |
| <b>Open questions / outstanding actions</b>         |  |



## WORKSHEET 3 OF 3

# Leadership Decision Record and Return Authorization

## Material decisions

| Date / time | Decision                           | Authority | Reason / evidence tradeoff |
|-------------|------------------------------------|-----------|----------------------------|
|             | Containment method                 |           |                            |
|             | Credential / session action        |           |                            |
|             | Carrier action                     |           |                            |
|             | Replacement tier A / B / C         |           |                            |
|             | Notification / legal / CI / COMSEC |           |                            |
|             | Remote wipe or destruction, if any |           |                            |

## Return-to-service authorization

|                                        |  |
|----------------------------------------|--|
| Replacement device / number / asset ID |  |
| Recovery tier and basis                |  |
| Credentials and sessions revalidated   |  |
| Carrier / MDM / platform validation    |  |
| Residual risk and monitoring plan      |  |
| Forensic lead approval                 |  |
| CISO / S6 / J6 approval                |  |

Legal / CI / COMSEC approval if required

Authorizing official / date

## Authoritative Source Basis and Limitations

This edition was checked against the following primary or national-authority sources as of August 20, 2026. Platform features and menus change; organizations should review this manual quarterly and after material iOS, Android, identity, carrier, or threat changes.

|      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| [1]  | Cybersecurity and Infrastructure Security Agency (CISA), <i>Mobile Communications Best Practice Guidance</i> , revision March 13, 2026.<br><a href="https://www.cisa.gov/resources-tools/resources/mobile-communications-best-practice-guidance">https://www.cisa.gov/resources-tools/resources/mobile-communications-best-practice-guidance</a>                                                                                                                                                                                                                                 |
| [2]  | Apple Support, <i>About Apple threat notifications and protecting against mercenary spyware</i> , published August 13, 2026.<br><a href="https://support.apple.com/en-us/102174">https://support.apple.com/en-us/102174</a>                                                                                                                                                                                                                                                                                                                                                      |
| [3]  | Apple Support, <i>About Lockdown Mode</i> , published January 23, 2026.<br><a href="https://support.apple.com/en-us/105120">https://support.apple.com/en-us/105120</a>                                                                                                                                                                                                                                                                                                                                                                                                           |
| [4]  | Google Android Help, <i>Improve device security with Advanced Protection for Android</i> , reviewed August 2026.<br><a href="https://support.google.com/android/answer/16339980">https://support.google.com/android/answer/16339980</a>                                                                                                                                                                                                                                                                                                                                          |
| [5]  | Google Android Help, <i>Log your Android device activity with Advanced Protection (Intrusion Logging)</i> , reviewed August 2026.<br><a href="https://support.google.com/android/answer/16927813">https://support.google.com/android/answer/16927813</a>                                                                                                                                                                                                                                                                                                                         |
| [6]  | Google Account Help, <i>Advanced Protection Program and common questions</i> , reviewed August 2026.<br><a href="https://support.google.com/accounts/answer/7539956">https://support.google.com/accounts/answer/7539956</a>                                                                                                                                                                                                                                                                                                                                                      |
| [7]  | National Institute of Standards and Technology, <i>NIST SP 800-61 Rev. 3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management</i> , April 2025.<br><a href="https://csrc.nist.gov/pubs/sp/800/61/r3/final">https://csrc.nist.gov/pubs/sp/800/61/r3/final</a>                                                                                                                                                                                                                                                                                  |
| [8]  | Scientific Working Group on Digital Evidence, <i>Best Practices for Mobile Device Evidence Collection &amp; Preservation, Handling, and Acquisition</i> , SWGDE 18-F-003-2.0, Version 2.0, August 21, 2025.<br><a href="https://www.swgde.org/documents/published-complete-listing/18-f-003-swgde-best-practices-for-mobile-device-evidence-collection-and-preservation-handling-and-acquisition/">https://www.swgde.org/documents/published-complete-listing/18-f-003-swgde-best-practices-for-mobile-device-evidence-collection-and-preservation-handling-and-acquisition/</a> |
| [9]  | Apple Support, <i>About Security Keys for Apple Account</i> , published April 28, 2026.<br><a href="https://support.apple.com/en-us/102637">https://support.apple.com/en-us/102637</a>                                                                                                                                                                                                                                                                                                                                                                                           |
| [10] | Apple Personal Safety User Guide, <i>Safety Check for an iPhone with iOS 16 or later</i> , published March 2026.<br><a href="https://support.apple.com/guide/personal-safety/ips2aad835e1/web">https://support.apple.com/guide/personal-safety/ips2aad835e1/web</a>                                                                                                                                                                                                                                                                                                              |
| [11] | UK National Cyber Security Centre, <i>Cyber security for high-risk individuals</i> , reviewed August 2026.<br><a href="https://www.ncsc.gov.uk/files/Cyber-security-high-risk-individuals.pdf">https://www.ncsc.gov.uk/files/Cyber-security-high-risk-individuals.pdf</a>                                                                                                                                                                                                                                                                                                        |
| [12] | National Institute of Standards and Technology, <i>NIST SP 800-124 Rev. 2, Guidelines for Managing the Security of Mobile Devices in the Enterprise</i> , May 2023.<br><a href="https://csrc.nist.gov/pubs/sp/800/124/r2/final">https://csrc.nist.gov/pubs/sp/800/124/r2/final</a>                                                                                                                                                                                                                                                                                               |
| [13] | National Institute of Standards and Technology, <i>NIST SP 800-101 Rev. 1, Guidelines on Mobile Device Forensics</i> , May 2014. Retained as background only; current platform-specific acquisition requires current tools and procedures.<br><a href="https://csrc.nist.gov/pubs/sp/800/101/r1/final">https://csrc.nist.gov/pubs/sp/800/101/r1/final</a>                                                                                                                                                                                                                        |
| [14] | Apple Support, <i>About Stolen Device Protection for iPhone</i> , published July 31, 2026.<br><a href="https://support.apple.com/en-us/120340">https://support.apple.com/en-us/120340</a>                                                                                                                                                                                                                                                                                                                                                                                        |

|             |                                                                                                                                                                                                                                                                |
|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>[15]</b> | Apple Support, <i>Check your Apple Account device list to find where you are signed in</i> , published December 16, 2025.<br><a href="https://support.apple.com/en-us/102649">https://support.apple.com/en-us/102649</a>                                       |
| <b>[16]</b> | Apple Personal Safety User Guide, <i>Review and delete configuration profiles</i> , published October 2025.<br><a href="https://support.apple.com/guide/personal-safety/ips327569a75/web">https://support.apple.com/guide/personal-safety/ips327569a75/web</a> |

## Limitations

- This guide is defensive and non-exhaustive. It does not replace organization-specific policy, classified-system directives, legal advice, provider support, or qualified forensics.
- A device can be compromised without obvious symptoms, and a symptom can have a benign cause. No checklist or scan can guarantee a device is clean.
- Menus, platform protections, logging, and provider recovery options vary by model, OS version, region, account type, and enterprise management.
- SWGDE guidance is written for trained evidence personnel. This executive manual translates selected preservation cautions into leader actions; it is not an acquisition procedure.
- NIST SP 800-101 Rev. 1 is older than current iOS and Android architectures and is retained only as background for enduring mobile-forensic principles.
- Organizations operating national security systems must use controlling authorities and approved tools.

## Publication QA/QC Record

This record documents the release controls applied to Edition 1.2.

| Control                            | Release criterion                                                                                                                                         | Result                                              |
|------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------|
| <b>Technical source control</b>    | Current CISA, Apple, Google, SWGDE and NIST sources reviewed; dates and feature caveats recorded.                                                         | Pass — 16 of 16 references re-verified; 1 corrected |
| <b>Anchor citation retrieval</b>   | Load-bearing citations retrieved in full and read against every claim drawn from them.                                                                    | Pass — refs [1], [2], [8]                           |
| <b>Operational sequence</b>        | Leader action, preservation, containment, scoping, investigation, recovery, and return-to-service are separated and ordered.                              | Pass — 6 phases, renumbered                         |
| <b>Forensic safety</b>             | State-changing actions are labelled; airplane mode, shutdown, RF isolation, reset, wipe, updates, scans, SIM changes and cables carry stated limitations. | Pass                                                |
| <b>Executive usability</b>         | 60-second card, containment matrix, role table, severity matrix, playbooks, readiness checklist, contents page and worksheets.                            | Pass                                                |
| <b>Military and legal controls</b> | Classified spill, COMSEC, CI, OPSEC, legal, privacy, records and command authorities defer to controlling procedures.                                     | Pass                                                |
| <b>Recovery integrity</b>          | High-consequence cases require clean provisioning, fresh identity and session controls, selective restore and formal return authorization.                | Pass                                                |
| <b>Language and safety</b>         | No exploit, surveillance, bypass, or offensive instructions; no claim that one tool or reset proves a device clean.                                       | Pass                                                |
| <b>Render and text integrity</b>   | Every cell wraps as a bounded paragraph; no fused word pairs, collided cells or truncated URLs.                                                           | Pass — rebuilt from source                          |
| <b>Publication review</b>          | Rendered to PDF; every page inspected; metadata set; file hashed.                                                                                         | Pass                                                |

## Revision governance

- Owner: GreyNOC Cybersecurity Operations.
- Review cycle: quarterly; after material iOS or Android security changes; after a relevant incident or exercise; and after controlling government or provider guidance changes.
- Change control: technical review, operational and legal review, executive usability review, visual QA, and signed publication record.
- Published by: GreyNOC Research Group, under the report designation Carbon6.
- Publication owner: GreyNOC Cybersecurity Operations.

### GREYNOC CLOSING DOCTRINE

Preserve evidence. Reduce attacker options. Verify every conclusion. When trust cannot be re-established after a high-consequence compromise, replacement from a known-good baseline is the honest technical answer.

**CARBON6 | GN-IR-MOBILE-001 | Edition 1.2 | August 20, 2026 | GreyNOC Research Group**